Bolsa de Empleo Tejedor — Documentación del proyecto en 11 pasos

Nov 8, 2026 · @Pablo

Resumen

Bolsa de Empleo Tejedor conecta a postulantes y comercios de Carlos Tejedor y la región, con ingreso por código de 6 dígitos al email y sin contraseñas. Este documento ordena el proyecto en los 11 pasos de un desarrollo web: qué se decidió, qué está hecho y qué falta en cada uno.

La app corre en React, TypeScript y Vite, con Supabase (base de datos y funciones), Netlify (sitio y funciones de servidor) y Brevo (correos). Las rondas de auditoría ya cerraron las fallas críticas del ingreso. La auditoría se dio por cerrada tras cinco rondas y el pulido final ya está en producción. Queda ejecutar las pruebas del paso 10 y preparar el lanzamiento.

Paso	Estado	Pendiente principal
1. Definir	Hecho	Aviso y consentimiento para el postulante (Ley 25.326)
2. Base de datos	Hecho	Catálogos de provincias y partidos sin uso en pantalla
3. Seguridad en la base	Hecho	Content-Security-Policy descartada por ahora (riesgo aceptado)
4. Estructura	Hecho	Configurar ESLint: hoy el comando lint solo revisa tipos
5. Acceso y registro	Hecho	Un email de otro rol aún se distingue de uno nuevo (riesgo bajo)
6. Versión de pruebas	Hecho	Probar en celulares reales
7. Funciones	Hecho	Paginar los directorios
8. Correos	Parcial	Reintentos y remitente con dominio propio

Paso	Estado	Pendiente principal
9. Panel de administración	Parcial	Botón Denunciar y motivo de cada moderación
10. Pruebas	Pendiente	Ejecutar el checklist completo
11. Lanzamiento	Pendiente	Copias de seguridad, monitoreo y rotar claves

Cada paso trae lo necesario para decidir y construir. Los pasos 2, 5, 7 y 9 incluyen diagramas y maquetas de las pantallas.

Paso 1. Definir

La plataforma tiene tres roles y una regla central: un email, un solo rol. Quien quiera buscar empleo y publicar como comercio usa dos correos distintos.

Reglas de negocio ya decididas

- El ingreso es por código de 6 dígitos enviado al email, sin contraseña. La cuenta se crea en el paso 1 del registro.
- La moderación es reactiva: los perfiles y las búsquedas se publican de inmediato y el administrador los pausa, reactiva o elimina después.
- Los filtros se eligen con un clic y tienen la opción "Otro"; el administrador suma los rubros nuevos al catálogo.
- El postulante indica su situación laboral: "Estoy buscando trabajo" o "Tengo trabajo, pero busco cambiar o sumar horas".
- Los comercios con cuenta activa pueden ver el CV y contactar por WhatsApp a los postulantes que están buscando.

Qué ve cada rol

Dato	Postulante	Comercio	Administrador
Nombre, foto, localidad, disponibilidad, formación, rubros y presentación	Los propios	Sí, de postulantes activos que buscan	Sí
CV en PDF	El propio	Sí, si el postulante está activo y buscando, o se postuló a ese comercio	Sí

Dato	Postulante	Comercio	Administrador
Teléfono / WhatsApp del postulante	El propio	Sí, al contactarlo o al recibir su postulación	Sí
Email y fecha de nacimiento del postulante	Los propios	No	Sí
Nombre, logo, rubro, localidad y descripción del comercio	Sí	Los propios	Sí
Teléfono y persona de contacto del comercio	No	Los propios	Sí
CUIT y razón social	No	Los propios	Sí
Búsquedas activas	Sí	Las propias	Sí

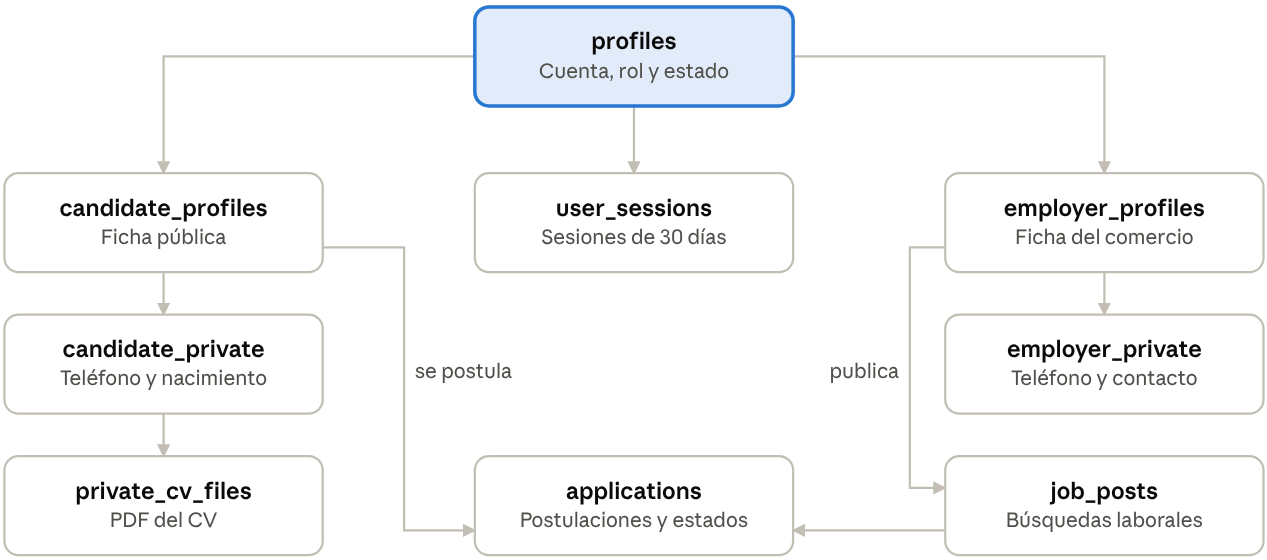
Decisiones abiertas

- Aviso de privacidad y consentimiento del postulante al registrarse, por la Ley 25.326 de protección de datos personales. Conviene consultarlo con un profesional.
- Qué pasa con el CV y los datos cuando el administrador da de baja una cuenta: hoy la baja es lógica y el archivo queda guardado.
- Si las búsquedas laborales vencen solas después de cierto tiempo.

Paso 2. Base de datos

La base separa lo público de lo privado: cada dato sensible vive en una tabla aparte a la que el navegador nunca accede directamente. El diagrama muestra cómo se relacionan las tablas principales.

Todo cuelga de profiles: cada cuenta tiene una ficha pública y otra privada



Cada flecha va de la tabla madre a la que depende de ella.
No dibujadas: contact_requests, contact_grants, admin_tickets, access_log, industries y email_otp_codes.

modelo de datos · 9 tablas principales

profiles es el centro. Un postulante tiene su ficha, sus datos privados y su CV; un comercio, su ficha, sus datos privados y sus búsquedas. Las postulaciones unen a ambos.

Tabla	Qué guarda
`profiles`	Cuenta: email, rol (`candidate` , `employer` , `admin`) y estado (`active` , `paused` , `deleted`)
`candidate_profiles`	Ficha pública del postulante: nombre, foto, ubicación, formación, rubros, disponibilidad y situación laboral
`candidate_private`	Teléfono, email y fecha de nacimiento del postulante
`private_cv_files`	PDF del CV (máximo 5 MB), guardado en la base y no en un bucket
`employer_profiles`	Ficha pública del comercio: nombre, logo, rubro, ubicación, descripción, CUIT
`employer_private`	Teléfono, email y persona de contacto del comercio

Tabla	Qué guarda
`job_posts`	Búsquedas laborales, con estado `active`, `paused` o `closed`, y marca de pausa del administrador
`applications`	Postulaciones: `received`, `in_review`, `shortlisted`, `hired`, `rejected`, `withdrawn`
`contact_requests`, `contact_grants`	Pedidos y permisos de contacto entre comercio y postulante; hay un solo pedido por pareja
`industries`	Catálogo de rubros con puestos sugeridos, editable por el administrador
`email_otp_codes`	Códigos de ingreso: solo el hash, intentos, vencimiento e IP
`user_sessions`	Sesiones de 30 días, con token aleatorio
`admin_tickets`	Consultas de los comercios al administrador, como conversación de hasta 30 mensajes, con estado pendiente o resuelta
`access_log`	Registro de quién abrió un CV, pidió un contacto o moderó, y sobre quién

Las tablas `reports`, `notification_outbox`, `provinces` y `districts` existen pero todavía no se usan: la pantalla toma las localidades de la API Georef.

`app_settings` es una tabla privada que guarda el email del administrador, para que esa dirección no quede escrita en el código.

Paso 3. Seguridad en la base

La app no usa Supabase Auth: el ingreso y las sesiones son propios, así que la protección vive en las funciones de la base y no en las políticas por usuario (RLS). Por eso cada función tiene que validar sesión y rol por su cuenta.

Control	Cómo funciona	Estado
Sin acceso directo a tablas	Se revocó todo acceso de `anon` y `authenticated`. El navegador solo llama funciones con el token de sesión	Hecho

Control	Cómo funciona	Estado
Código de ingreso	Se genera en el servidor, se guarda solo su hash, vence a los 10 minutos y admite 5 intentos	Hecho
Pedidos de código	Hasta 8 por hora por email y 30 por hora por IP, con captcha Turnstile. No se invalida un código vigente emitido hace menos de 2 minutos	Hecho
Funciones de servidor	`server_issue_otp_challenge` y `server_prepare_notification_email` solo las puede ejecutar `service_role`, sin claves en el código	Hecho
Rol en cada función	Postulante, comercio o administrador se valida adentro de cada función	Hecho
CV privado	El PDF se valida en el servidor (firma `%PDF-`, 5 MB) y solo lo abre una función con sesión y permiso	Hecho
Registro de accesos al CV	Cada apertura de un CV y cada pedido de contacto se anotan en `access_log`	Hecho
Fotos y logos	Solo imágenes WebP, JPEG o PNG de hasta 600 KB	Hecho
Sesiones	30 días, se revocan al salir y se rechazan en cuentas pausadas o dadas de baja	Hecho
Correos	HTML escapado y sin repetir avisos	Hecho
Cabeceras del sitio	`X-Frame-Options`, `nosniff`, `Referrer-Policy` y `Permissions-Policy`	Hecho. No se agrega `Content-Security-Policy`
Tope de contactos	Un comercio pide hasta 30 contactos nuevos cada 24 horas; volver a contactar al mismo postulante no suma. El administrador queda exento	Hecho
Cuenta del administrador	Su email vive en la tabla privada app_settings, no en el código, y no puede pausar ni eliminar su propia cuenta	Hecho

Control	Cómo funciona	Estado
Panel del administrador	La función del panel devuelve columnas explícitas y solo la ruta segura al CV, sin campos heredados	Hecho

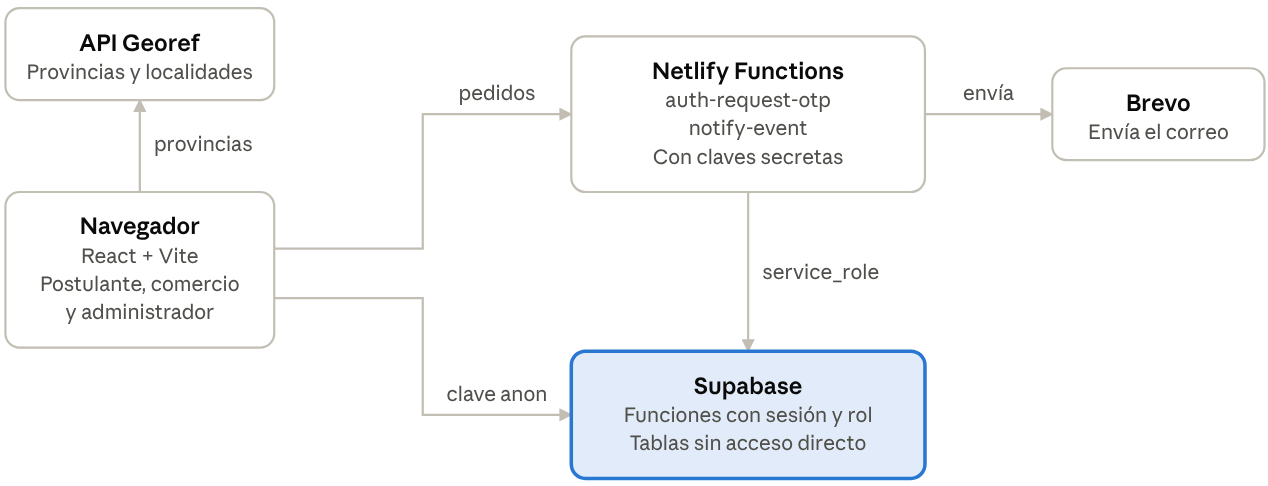
Reglas para toda función nueva

- Usar `SECURITY DEFINER` con `SET search_path = public, extensions`.
- Validar el token con `get_session_profile` y el rol antes de leer o escribir.
- Devolver solo los campos que esa pantalla necesita, nunca emails ajenos.
- Cuando falla algo esperable, devolver `{ok:false, error}` en vez de lanzar una excepción, porque la excepción deshace los cambios de esa llamada, incluidos los contadores.
- Ninguna clave en el código ni en el repositorio: solo variables de entorno de Netlify.

Paso 4. Estructura del proyecto

El proyecto es una sola aplicación web con un backend mínimo: el navegador habla con Supabase, y Netlify aporta dos funciones de servidor para lo que necesita claves secretas. El stack es React 18, TypeScript y Vite, con Tailwind 3.4 y React Router 6.

El navegador solo habla con Supabase; las claves secretas viven en Netlify



arquitectura · 4 componentes y 1 API externa

El navegador pide los datos a Supabase con el token de sesión. El código de ingreso y los avisos pasan por las funciones de Netlify, que son las únicas con claves secretas.

```
.
├── docs/                    ARQUITECTURA, DECISIONES, SEGURIDAD
├── netlify/functions/
|   ├── auth-request-otp.mjs   emite el código y lo envía por Brevo
|   └── notify-event.mjs       arma y envía los correos de avisos
├── supabase/migrations/     una migración por cambio, en orden de fecha
├── src/
|   ├── components/layout, ui  MainLayout, AdminLayout, ChipSelector,
LocationSelector
|   ├── context/AuthContext.tsx  sesión y cierre de sesión
|   ├── lib/                     supabase, emailService, imageCompression,
pdfValidation
|   ├── pages/                   una pantalla por archivo
|   └── types/database.ts
├── netlify.toml             redirecciones y cabeceras
└── .env.example             variables necesarias, sin valores reales
```

Variables de entorno

Variable	Dónde	Para qué
`VITE_SUPABASE_URL`, `VITE_SUPABASE_ANON_KEY`	Navegador	Conectar con Supabase. La clave `anon` es pública por diseño
`VITE_APP_NAME`	Navegador	Nombre que se muestra en el sitio
`SUPABASE_SERVICE_ROLE_KEY`	Solo servidor	Llamar las funciones de servidor. Nunca con prefijo `VITE_`
`BREVO_API_KEY`	Solo servidor	Enviar correos
`BREVO_SENDER_EMAIL`, `BREVO_SENDER_NAME`	Solo servidor	Remitente y nombre que ve quien recibe el correo
`TURNSTILE_SECRET_KEY`, `VITE_TURNSTILE_SITE_KEY`	Servidor y navegador	Captcha del ingreso (ronda 3)

Convenciones

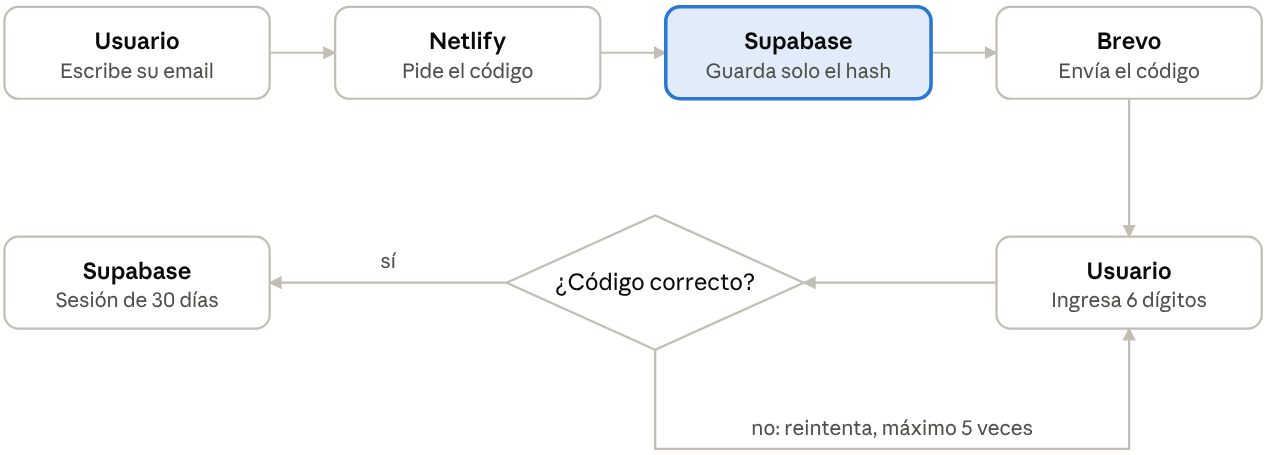
- Cada cambio de base de datos es una migración nueva; las ya aplicadas no se editan.

- Una pantalla por archivo en `pages/`; lo reutilizable va en `components/` y `lib/`.
- Las fotos se comprimen a WebP en el navegador antes de subirse.

Paso 5. Acceso y registro

El ingreso es un código de 6 dígitos que llega al email y vence a los 10 minutos; el mismo flujo crea la cuenta la primera vez. El navegador nunca recibe el código: lo genera el servidor, lo guarda con hash y lo manda por Brevo.

El código nunca viaja al navegador: se guarda con hash y llega por correo

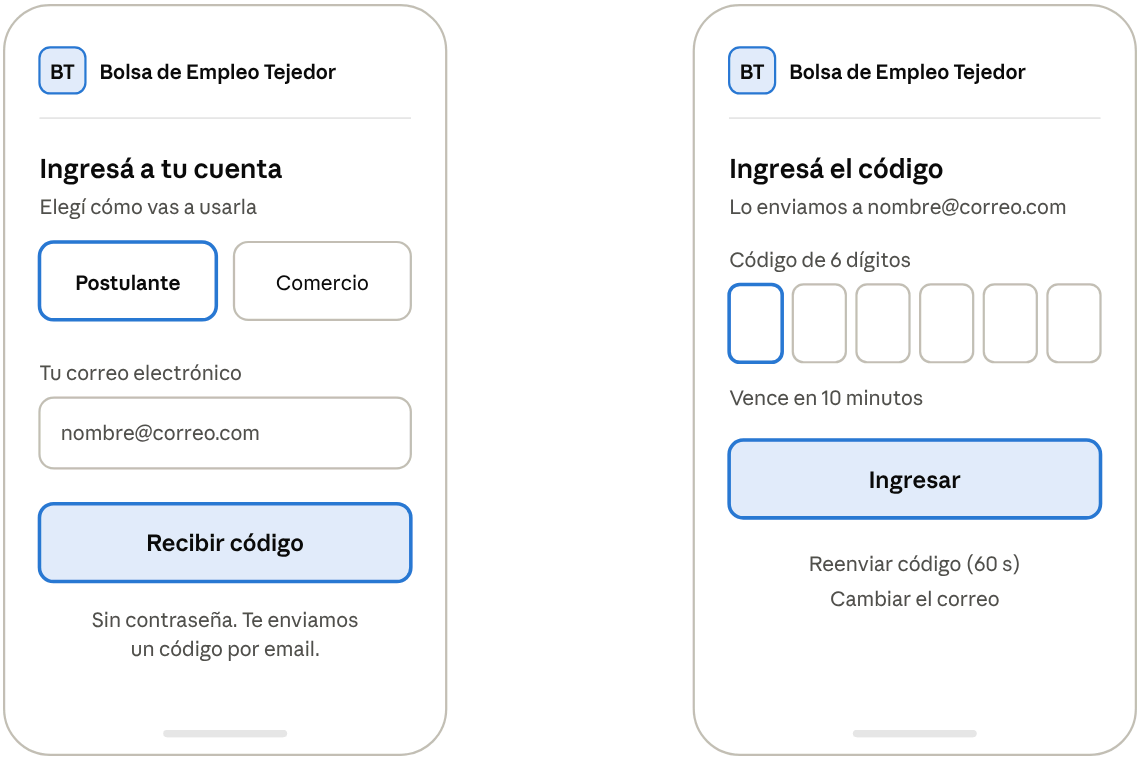


El código vence a los 10 minutos. Si se agotan los 5 intentos, hay que pedir uno nuevo.

flujo de ingreso · 6 pasos y 1 decisión

El servidor pide y guarda el código, Brevo lo envía y la base lo verifica. La sesión solo se crea cuando el código es correcto.

Ingresar lleva dos pasos: rol y email, y después el código



1. Elegir rol y pedir el código

2. Ingresar el código

maqueta de /ingresar · 2 pantallas de celular

En el celular, cada paso ocupa una pantalla completa: primero el rol y el correo, después los seis dígitos.

Reglas del ingreso

- El postulante o el comercio elige su rol en `/ingresar`. El administrador entra por `/admin`.
- Un email ya registrado con otro rol no puede entrar con el rol equivocado.
- El botón de reenvío espera 2 minutos y el servidor no invalida un código vigente emitido hace menos de 2 minutos. Cada pedido exige resolver el captcha de nuevo.
- Después de 5 códigos incorrectos hay que pedir uno nuevo.
- La sesión dura 30 días y se revoca en el servidor al cerrar sesión.
- El primer ingreso lleva a completar el perfil: el postulante va a `/mi-perfil` y el comercio a `/mi-comercio`.

Cerrado en la ronda 3

- Captcha (Cloudflare Turnstile) antes de pedir el código; si falta la clave secreta, el servidor rechaza el pedido.
- Mensaje de error genérico para cuentas pausadas, eliminadas o de otro rol. Queda una diferencia: un email nuevo recibe código y uno registrado con otro rol recibe un error; el captcha y los límites lo vuelven de riesgo bajo.

Sesiones por rol

- Postulante, comercio y administrador pueden tener sesión abierta a la vez en el mismo navegador; cada pantalla usa la sesión del rol que corresponde a su ruta.
- Al abrir el sitio, y al volver a la pestaña (como máximo una vez por minuto), la sesión se revalida contra el servidor. Si ya no vale (vencida, cuenta pausada o eliminada), se cierra solo esa sesión y aparece "Tu sesión finalizó. Ingresá de nuevo."
- Un corte de red o un error del servidor no cierra la sesión.
- Salir cierra solo la sesión del rol que se está usando.

Paso 6. Versión de pruebas temprana

El sitio se publica en Netlify desde GitHub apenas funciona el ingreso, para probar en celulares reales antes de sumar más funciones. Cada cambio que se sube a GitHub genera un despliegue nuevo.

Configuración de Netlify

- Comando de compilación `npm run build`, carpeta publicada `dist`, funciones en `netlify/functions`.
- Las rutas `/api/*` se redirigen a las funciones y el resto cae en `index.html`, porque es una aplicación de una sola página.
- Las variables de entorno del paso 4 se cargan en Netlify, nunca en el repositorio.

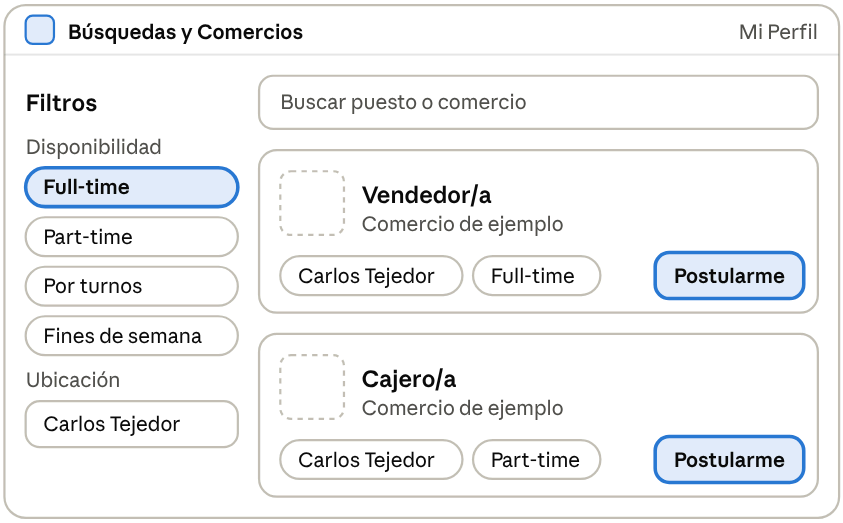
Orden de arranque

- [ ] Crear el proyecto en Supabase y aplicar las migraciones en orden de fecha.
- [ ] Cargar las variables de entorno en Netlify y conectar el repositorio de GitHub.
- [ ] Verificar el dominio del remitente en Brevo (SPF, DKIM y DMARC) para que los códigos no caigan en spam.
- [ ] Probar el ingreso con un postulante, un comercio y el administrador.
- [ ] Abrir el sitio en al menos un Android y un iPhone.

Paso 7. Funciones, de a una

Las funciones se construyen de adentro hacia afuera: primero el perfil, después las búsquedas, las postulaciones y por último el contacto. Cada una se prueba en el celular antes de empezar la siguiente.

Los filtros se ven siempre en la computadora y se pliegan en el celular



Computadora: filtros a la izquierda y tarjetas a la derecha



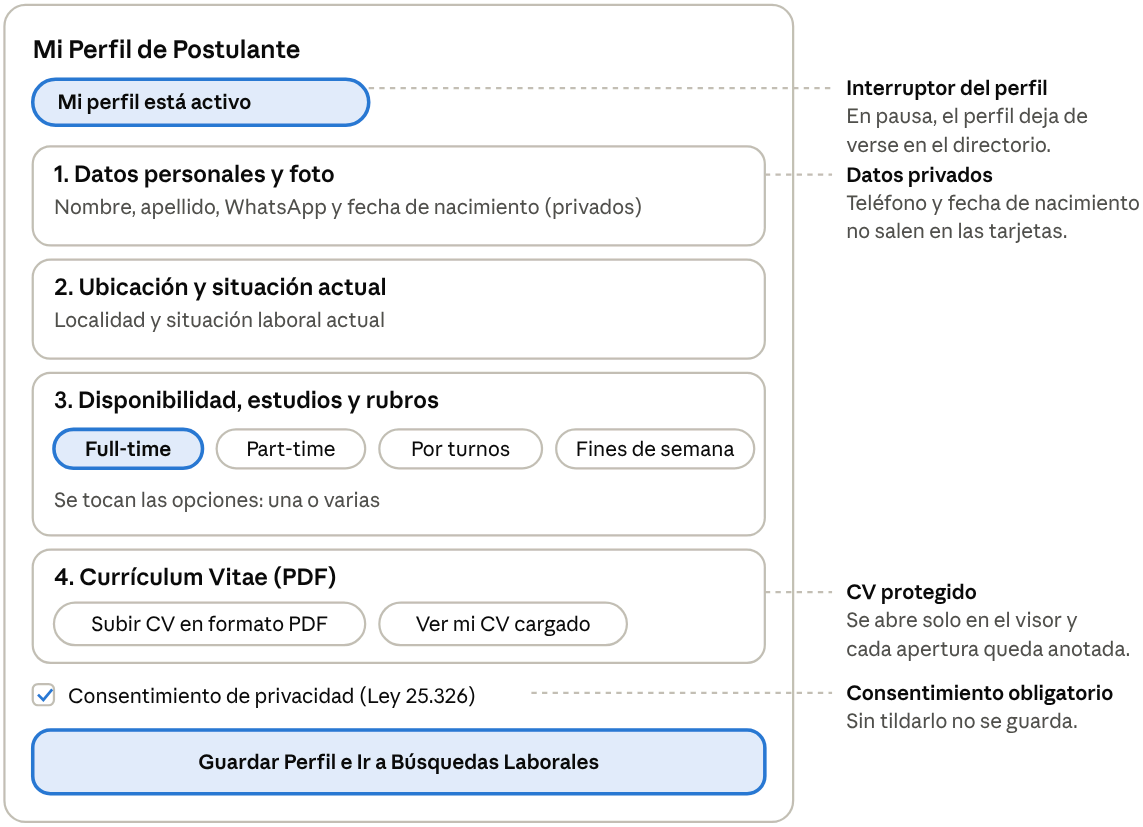
Celular: filtros plegados

maqueta de /vacantes · computadora y celular, con datos de ejemplo

El listado de postulantes del comercio (`/postulantes`) usa la misma estructura: filtros por situación laboral, disponibilidad, formación y rubro, y tarjetas con las acciones Ver CV y Contactar.

Mi perfil de postulante (`/mi-perfil`)

Mi perfil se completa en cuatro secciones y se puede pausar

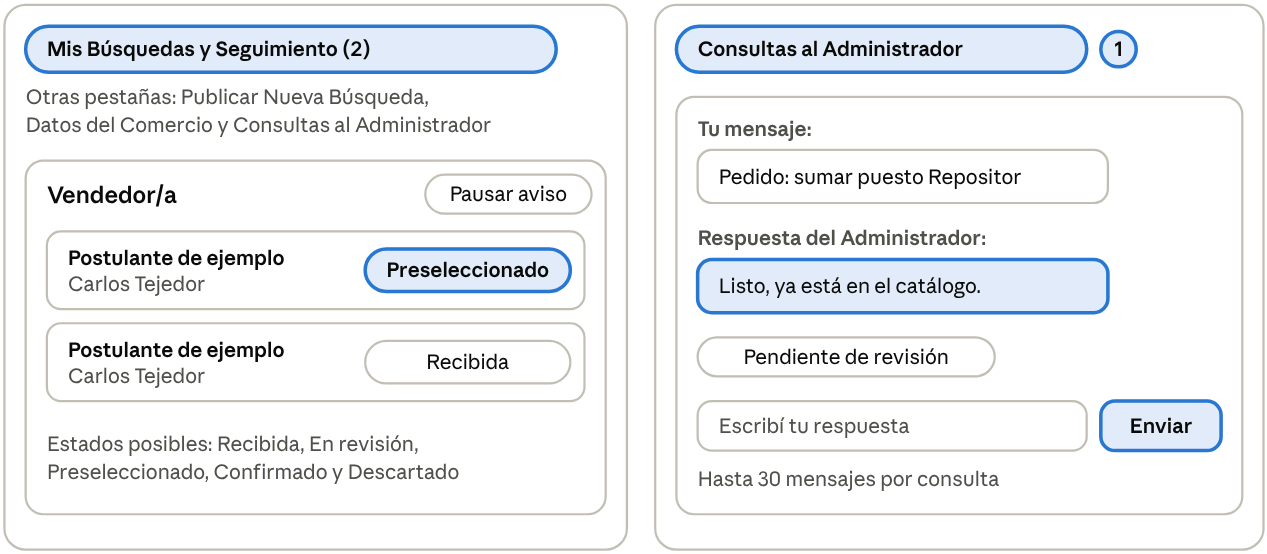


maqueta de /mi-perfil · 4 secciones, interruptor y consentimiento

El postulante completa cuatro secciones y acepta el consentimiento de privacidad. El interruptor de arriba pausa su perfil cuando quiera.

Panel de Mi comercio (`/mi-comercio`)

Mi comercio junta búsquedas, postulantes y consultas en un solo panel



Cambiar el estado avisa al postulante por correo

Se actualiza sola cada 30 s con esta pestaña abierta

maqueta de /mi-comercio · búsquedas con postulantes y consultas

Cada comercio ve sus búsquedas con los postulantes y sus estados. Las consultas al administrador son una conversación que se refresca sola cada 30 segundos, y solo con esa pestaña abierta.

Ruta	Rol	Qué hace
`/ingresar`	Postulante y comercio	Elegir rol, pedir el código e ingresar
`/mi-perfil`	Postulante	Cargar datos, foto, CV, situación laboral, disponibilidad y rubros; pausar la búsqueda
`/vacantes`	Postulante	Ver búsquedas y comercios con filtros, y postularse
`/mi-comercio`	Comercio	Datos del comercio, publicar búsquedas, seguir postulantes y consultar al administrador
`/postulantes`	Comercio	Ver postulantes con filtros, abrir el CV y contactar por WhatsApp
`/ver-cv/:id`	Comercio, postulante y administrador	Abrir el PDF del CV si hay permiso

Ruta	Rol	Qué hace
`/admin`	Administrador	Moderación y consultas (paso 9)

Postulaciones

El comercio mueve cada postulación por cinco estados y el postulante recibe un aviso por correo en cada cambio. El postulante puede retirarla, salvo que ya haya sido rechazada.

En la pantalla del comercio, "Mis Búsquedas y Seguimiento" tiene un filtro por texto y por estado, y cada tarjeta muestra de 2 a 3 postulantes con scroll interno.

Detalles que cuidar

- Los filtros se pliegan en el celular con el botón "Mostrar / Ocultar Filtros".
- La búsqueda ignora tildes y la diferencia de género (vendedor, vendedora).
- El número de WhatsApp se normaliza al formato argentino. En la ronda 3 se corrige para los códigos de área del interior.
- Los listados traen todos los registros de una vez; cuando crezcan hay que paginarlos.

Paso 8. Correos automáticos

La app envía cinco correos, todos desde el servidor por Brevo y con el nombre "Bolsa de Empleo Tejedor" como remitente. Se agregan después de que los eventos ya existen, para no automatizar algo que todavía cambia.

Correo	Quién lo recibe	Cuándo sale
Código de ingreso	Quien quiere entrar	Al pedir el código
Nueva postulación	El comercio	Cuando un postulante se postula a una búsqueda
Cambio de estado	El postulante	Cuando el comercio cambia el estado de su postulación
Nueva consulta	El administrador	Cuando un comercio le escribe o responde en una consulta
Respuesta	El comercio	Cada vez que el administrador responde (se evitan repetidos en 15 segundos)

Cómo se arma cada aviso

- El navegador solo envía el tipo de evento y el identificador. El texto y el destinatario los arma la base, y el navegador nunca ve el email de la otra parte.
- Todo el contenido que escribe un usuario se escapa antes de entrar al HTML.
- Cada aviso queda marcado como enviado para que no se pueda repetir. El aviso de cambio de estado solo sale si el estado cambió desde el último avisado, y se reinicia si el postulante se vuelve a postular.

Pendiente

- Si Brevo falla, el servidor desmarca el aviso y responde error 502, así se puede reintentar; todavía no hay reintento automático.
- El remitente debe ser una dirección de un dominio propio verificado en Brevo, no un Gmail, para que los correos no caigan en spam. Si falta el remitente configurado, el servidor rechaza el envío en vez de usar uno por defecto.
- Para avisos que no se pueden perder, falta una cola de envíos con reintentos.

Paso 9. Panel de administración y moderación

El administrador modera después de la publicación, con un clic: pausa, reactiva o elimina perfiles y búsquedas desde `/admin`. El panel se abre por la dirección directa y exige ingresar con código y rol de administrador.

Cada ficha del panel permite ver, contactar y moderar en un clic



Panel /admin: resumen, listados y ficha con acciones de moderación (datos de ejemplo)

maqueta de /admin · resumen, listado y ficha

Al tocar una fila se abre la ficha con los datos privados, el visor del CV y los tres botones de moderación.

Qué incluye

- Tarjetas de resumen arriba y listados de postulantes, comercios y búsquedas, con los mismos filtros que ve el resto de la plataforma.
- Una ventana con la ficha completa de cada elemento: datos de contacto, acceso a WhatsApp, visor del CV y botones de moderación.
- La pestaña "Consultas de Comercios", donde se responden los pedidos de nuevos rubros o puestos. Cada consulta es una conversación de ida y vuelta (hasta 30 mensajes) que sigue abierta hasta que el administrador la marca como resuelta; cada mensaje avisa a la otra parte por correo.
- La gestión del catálogo de rubros y puestos sugeridos.

Reglas de moderación

- Una búsqueda pausada por el administrador no la puede reactivar el comercio: debe escribirle desde su panel.
- Una cuenta pausada no puede iniciar sesión y sus búsquedas dejan de verse. Una cuenta eliminada pierde sus sesiones.

- La cuenta del administrador no puede pausarse ni eliminarse a sí misma, y al aplicar la migración final se la deja activa.
- Las consultas se refrescan solas cada 30 segundos, y solo mientras la pestaña de consultas está abierta y la ventana a la vista. En las demás pestañas la pantalla se actualiza al cambiar de pestaña o al volver a la ventana. Es igual en Mi comercio y evita descargar todos los postulantes cada pocos segundos.

Pendiente

- Botón "Denunciar" en perfiles y avisos para que los usuarios avisen de un problema.
- Registro de quién modera, a quién y por qué.

Paso 10. Pruebas de seguridad, rendimiento y errores

Antes de lanzar hay que ejecutar este checklist sobre el sitio real: las pruebas de seguridad se hacen contra la base, no solo mirando las pantallas.

Seguridad

- [ ] Poner 5 códigos incorrectos seguidos y después el correcto: debe pedir un código nuevo.
- [ ] Llamar `server_issue_otp_challenge` desde la consola con la clave `anon`: debe dar `permission denied`.
- [ ] Con una cuenta de comercio, llamar `save_candidate_profile`: debe rechazarlo.
- [ ] Abrir el CV de un postulante pausado o que no busca, sin postulación a ese comercio: debe rechazarlo.
- [ ] Enviar dos veces el aviso `new_application` del mismo `targetId`: el segundo debe fallar.
- [ ] Confirmar que no quedan PDF viejos en el bucket `cvs` y que no hay claves en el repositorio.

Ingreso y datos

- [ ] Pedir un código con un email de otro rol: no debe revelar qué cuenta existe.
- [ ] Subir un archivo que no sea PDF y uno de más de 5 MB: ambos deben rechazarse.
- [ ] Postularse dos veces a la misma búsqueda, y retirar y volver a postularse.
- [ ] Cargar teléfonos de 11, de 3 dígitos de área (351, 236) y de 4 dígitos (2314): el enlace de WhatsApp debe quedar bien.

Rendimiento y celular

- [ ] Recorrer el sitio en un Android y un iPhone con conexión lenta.
- [ ] Medir el tiempo de carga de los listados con 200 o más registros.
- [ ] Verificar los filtros plegables y las tarjetas con scroll en pantallas de 360 px.

Errores

- [ ] Cortar el envío de correo (clave de Brevo inválida): la pantalla debe mostrar un mensaje claro y no perder datos.
- [ ] Abrir el sitio con la sesión vencida: debe volver a `/ingresar` sin pantallas rotas.

Paso 11. Lanzamiento

Se lanza cuando el checklist del paso 10 está completo y las claves están rotadas: el sitio sale a producción con respaldo y alguien mirando que funcione. Conviene lanzar primero con un grupo chico de comercios y postulantes.

Antes de publicar

- [ ] Rotar la clave `service_role` de Supabase y la clave de Brevo si el repositorio fue público alguna vez.
- [ ] Confirmar que las claves existen solo en las variables de entorno de Netlify.
- [ ] Configurar el dominio propio y el remitente verificado en Brevo.
- [ ] Agregar la política `Content-Security-Policy` en `netlify.toml`.
- [ ] Publicar el aviso de privacidad y los términos de uso, revisados por un profesional.
- [ ] Agregar ícono del sitio y vista previa para compartir en redes (`index.html` todavía no los tiene).

Respaldo y monitoreo

- [ ] Activar las copias de seguridad de Supabase y probar una restauración.
- [ ] Agregar monitoreo de errores (por ejemplo Sentry) en el sitio y las funciones.
- [ ] Alertas por correo si falla el envío de códigos.

Primeras semanas

- Revisar a diario el panel de administración y las consultas de los comercios.
- Mirar el uso de la base y del plan de Brevo, porque los CV guardados en la base la hacen crecer.
- Anotar los pedidos de rubros nuevos para ampliar el catálogo.